

VENDOR MANAGEMENT POLICY

Company:	Duke University Health Systems	Document Owner:	Tia Mitchell
Revision:	DUHS-VRM-001	Initial Date:	04/11/2026
Applies To:	DUHS Personnel and Vendors	Next Review Date:	04/11/2027

PURPOSE

This policy is intended to ensure that third-party vendors are managed in a manner that protects Duke University Health System's sensitive data, including protected health information (PHI), and supports compliance with applicable healthcare and security regulations.

SCOPE

This policy applies to all Duke University Health System (DUHS) employees, contractors, and business units engaged in the procurement, onboarding, management, and termination of third-party vendors. It covers all vendor relationships that may impact DUHS data, systems, operations, or regulatory obligations, including vendors with access to sensitive or protected health information (PHI).

DEFINITIONS

- **Vendor/Third-Party**
 - An external organization or individual that provides products or services to Duke University Health Systems (DUHS).
- **Third-Party Risk**
 - The potential for financial, operational, regulatory, or reputational harm resulting from relationships with external vendors.
- **Sensitive Data**
 - Any information requiring protection due to regulatory, contractual, or business obligations, including but not limited to personal, financial, confidential, or protected health information (PHI).
- **Protected Health Information (PHI)**
 - Individually identifiable health information that is protected under applicable healthcare privacy regulations, including the Health Insurance Portability and Accountability Act (HIPAA).
- **Vendor Tiering**
 - The process of classifying vendors based on their level of risk, criticality, and impact on DUHS operations, data, and. Regulatory obligations.
- **Due Diligence**
 - The process of evaluating a vendor's security, compliance, financial stability, and operational practices before engagement.
- **Ongoing Monitoring**
 - The continuous assessments of a vendor's performance, risk posture, and compliance throughout the lifecycle of the vendor relationship.
- **Access**
 - The ability of a vendor to interact with DUHS systems, data, networks, or physical facilities.
- **Business Associate**
 - A vendor that creates, maintains, or transmits protected health information (PHI) on behalf of DUHS.
- **Business Associate Agreement (BAA)**
 - A legally binding agreement between DUHS and a Business Associate that establishes requirements for safeguarding protected health information (PHI) in accordance with applicable regulations.

GOVERNANCE, ROLES AND ACCOUNTABILITY

Duke University Health System (DUHS) establishes the following roles and responsibilities for the management of third-party vendors:

- **Audit and Compliance Team**
Responsible for overseeing adherence to this policy, conducting vendor risk assessments, and validating that vendors meet DUHS security, regulatory, and contractual requirements.
- **Information Security / Security Operations Center (SOC)**
Responsible for monitoring vendor-related security risks, identifying potential threats or incidents, and coordinating with internal teams to respond to and remediate security events involving third-party vendors
- **System Owners / Business Owners**
Responsible for initiating vendor engagements, ensuring business justification, and maintaining oversight of vendor performance and risk throughout the vendor lifecycle.
- **Approval Authority (e.g., CISO or designated leadership)**
Responsible for approving vendor engagements, risk acceptance decisions, and any exceptions to this policy. This role ensures that vendor relationships align with DUHS risk tolerance and regulatory obligations.
- **Procurement / Vendor Management Function**
Responsible for coordinating vendor onboarding, contract management, and ensuring required documentation (e.g., agreements, assessments) is completed before engagement.
- **Vendors / Third Parties**
Responsible for complying with DUHS security, privacy, and regulatory requirements, including safeguarding DUHS data, reporting risks or incidents promptly, and adhering to agreed-upon contractual obligations.
- **Privacy / Compliance Officer**
Responsible for ensuring that all vendor relationships comply with applicable healthcare privacy and regulatory requirements, including HIPAA and related laws. This role oversees the protection of protected health information (PHI), reviews and approves Business Associate Agreements (BAAs), and ensures vendors meet DUHS privacy and compliance standards throughout the vendor lifecycle.

VENDOR RISK TIERING (TIER 1, TIER 2, TIER 3)

Duke University Health System (DUHS) classifies vendors based on the level of risk, access, and impact they pose to organizational operations, data, and regulatory obligations. Vendor tiering determines the level of oversight, due diligence, and monitoring required throughout the vendor lifecycle.

TIER 1 – Critical / High-Risk Vendors

- Vendors that provide mission-critical services or have access to sensitive systems or data, including protected health information (PHI). These vendors have a direct impact on patient care, operational continuity, or regulatory compliance.

Examples: Cloud service providers handling PHI, electronic health record (EHR) vendors, critical infrastructure providers, and emergency or clinical service partners.

TIER 2 – Moderate-Risk Vendors

- Vendors that support important business operations but do not have the same level of critical impact as Tier 1 vendors. These vendors may have limited access to systems or sensitive data, which could impact operations if disrupted.

Examples: IT service providers, specialized equipment vendors, and third-party service providers supporting business functions.

TIER 3 – Low Risk Vendors

- Vendors that provide goods or services with minimal impact on operations, systems, or sensitive data. These vendors typically do not have access to sensitive systems or protected data.

Examples: Office supply vendors, non-critical service providers, and low-impact contractors.

DUE DILIGENCE AND MINIMUM CONTROL REQUIREMENTS

Duke University Health System (DUHS) requires that all third-party vendors undergo appropriate due diligence and meet minimum security and compliance requirements before engagement and throughout the vendor lifecycle.

Due Diligence Requirements

Before onboarding, vendors must be evaluated to assess their risk, security posture, and ability to meet DUHS requirements. Due diligence activities may include:

- Review of vendor security policies, procedures, and controls
- Assessments of prior security incidents and risk history
- Evaluation of incidents and risk history
- Evaluation of incident response plans and capabilities
- Financial and operational risk assessments
- Validation of applicable certifications and compliance reports (e.g., SOC reports)

Minimum Security and Compliance Requirements

All vendors must meet baseline security and regulatory requirements aligned with DUHS standards, including but not limited to:

- Compliance with applicable healthcare regulations (e.g., HIPAA)
- Alignment with recognized security frameworks (e.g., NIST, ISO 27001)
- Implementation of appropriate access controls, encryption, and data protection measures
- Ability to detect, respond to, and report security incidents promptly

Vendors handling protected health information (PHI) must meet additional privacy and security requirements and execute a Business Associate Agreement (BAA), where applicable.

Contractual and Legal Requirements

All vendors must enter into appropriate contractual agreements with DUHS, which may include:

- Non-Disclosure Agreements (NDAs)
- Business Associate Agreements (BAAs), where applicable
- Defined security, privacy, and data protection obligations

Failure to meet DUHS security, compliance, or contractual requirements may result in corrective action, up to and including termination of the vendor relationship, in accordance with contractual terms.

Data Handling and Retention Requirements

Vendors must:

- Define how DUHS data is collected, processed, stored, and transmitted
- Establish data retention timelines in accordance with regulatory and business requirements
- Ensure secure disposal or return of DUHS data upon contract termination
- Notify DUHS of any changes that may impact data protection or handling practices

APPROVAL PROCESS

All third-party vendors must undergo a formal approval process before engaging with Duke University Health System (DUHS).

1. Vendor Request Initiation

Business or system owners must submit a vendor request, including a business justification, scope of services, and expected access to DUHS systems, data, or facilities.

2. Vendor Risk Assessment and Tiering

The vendor is evaluated to determine its risk classification (Tier 1, Tier 2, or Tier 3) based on factors such as data access, system access, and operational impact.

3. Security and Compliance Review

The Information Security team, Audit/Compliance team, and Privacy/Compliance Officer review the vendor to ensure alignment with DUHS security, privacy, and regulatory requirements.

4. Due Diligence and Documentation Review

Required documentation is collected and reviewed, which may include:

- Security policies and procedures
- Compliance certifications (e.g., SOC reports)
- Incident response capabilities
- Risk assessments and supporting documentation

5. **Contractual Agreements**

All required agreements must be executed before onboarding, including:

- Non-Disclosure Agreements (NDAs)
- Business Associate Agreements (BAAs), where applicable
- Vendor contracts outlining security, privacy, and service obligations

6. **Final Approval**

The Approval Authority (e.g., CISO or designated leadership) reviews the assessment results and formally approves or denies the vendor engagement. Any identified risks must be accepted or remediated before approval.

7. **Vendor Onboarding**

Upon approval, the vendor is onboarded in accordance with DUHS procedures, including system access provisioning, communications of requirements, and assignment of internal points of contact.

ONGOING MONITORING

Duke University Health System (DUHS) performs ongoing monitoring of third-party vendors to ensure continued compliance with security, privacy, and regulatory requirements throughout the vendor lifecycle. Monitoring activities are commensurate with the vendor's risk tier and level of access to DUHS systems and data.

Monitoring Activities

Ongoing monitoring may include, but is not limited to:

- Periodic review of vendor compliance certifications and audit reports (e.g., SOC reports)
- Evaluation of vendor performance and adherence to contractual obligations
- Monitoring for changes to vendor systems, services, or security practices that may impact DUHS
- Review and follow up on identified risks, vulnerabilities, or incidents
- Validation that vendors continue to meet DUHS security and privacy requirements

Security and Risk Oversight

DUHS may:

- Monitor for security incidents or threats associated with vendor systems or services
- Require vendors to report security incidents or breaches in accordance with contractual obligations
- Reassess vendor risk when significant changes occur (e.g., system changes, new services, regulatory updates)

Policy and Compliance Alignment

Vendors are expected to:

- Maintain alignment with DUHS security, privacy, and compliance requirements
- Notify DUHS of material changes to their policies, controls, or operating environment
- Provide updated documentation or evidence of compliance upon request

OFFBOARDING

Duke University Health System (DUHS) requires that all vendor relationships be formally offboarded to protect DUHS data, systems, and operations upon termination of services.

Access Removal

- All vendor access to DUHS systems, networks, and facilities must be revoked promptly upon termination of the relationship.
- System owners are responsible for validating that access has been fully removed.

Data Return and Disposal

Vendors must:

- Return or securely dispose of DUHS data in accordance with contractual and regulatory requirements
- Confirm data destruction or return, where applicable
- Adhere to defined data retention timelines and disposal methods

Asset and Property Management

- Vendors must return all DUHS-owned assets, equipment, and materials
- Vendors must disclose any remaining access points or dependencies associated with their services

Transition and Knowledge Transfer

- Vendors must support, where applicable, the transition of services to ensure continuity of operations.
- Relevant documentation, system information, and contacts must be transferred to DUHS or a designated party.

Post-Termination Obligations

- Vendors remain subject to ongoing confidentiality and data protection obligations as defined in contractual agreements.
- DUHS may request reasonable support from vendors following termination to address audit, compliance, or operational inquiries

EXCEPTIONS

Any exceptions to this policy must be formally documented and approved before implementation.

Exception requests must include a business justification, a description of the associated risks, and any proposed compensating controls to mitigate those risks.

All exceptions must be reviewed and approved by the designated Approval Authority (e.g., the Chief Information Security Officer or an authorized delegate) and, where applicable, by the Privacy/Compliance Officer.

Approved exceptions must be time-bound and subject to periodic review to ensure continued validity and risk acceptance.

Failure to obtain proper approval for policy exceptions may result in non-compliance with DUHS security and regulatory requirements.

RECORDS, COMPLIANCE, AND STANDARDS

DUHS maintains records to demonstrate compliance with this policy and to support audit, regulatory, and operational requirements.

Records Management

The following records must be maintained, where applicable:

- Vendor risk assessments and tiering classifications
- Due diligence documentation and supporting evidence
- Contracts, Non-Disclosure Agreements (NDAs), and Business Associate Agreements (BAAs)
- Security and compliance certifications (e.g., SOC reports)
- Ongoing monitoring activities, reviews, and findings
- Incident reports and risk remediation documentation
- Vendor onboarding and offboarding records

All records must be retained in accordance with DUHS record retention policies and applicable regulatory requirements.

Compliance and Standards

This policy aligns with applicable legal, regulatory, and industry standards, including but not limited to:

- Health Insurance Portability and Accountability Act (HIPAA)
- Health Information Technology for Economic and Clinical Health (HITECH) Act
- NIST Risk Management Framework (RMF)
- NIST SP 800-53 Security and Privacy Controls
- ISO/IEC 27001 Information Security Management Standard
- SOC 1 and SOC 2 Reporting Frameworks
- Payment Card Industry Data Security Standard (PCI-DSS), where applicable

DUHS may also consider additional regulatory, contractual, or organizational requirements when managing vendor relationships.

The Institute for Public Procurement: <https://www.nigp.org/blog/vendor-tiering>